

Rule implementation framework

Olof Magnusson

August 10, 2025

1 Introduction

The process of developing rules to capture threat actor behavior can sometimes be inconsistent, messy, and lack the systematic rigor necessary for deployment.

Without a structured approach, people often find themselves lost with detection rules that usually generate a vast number of false positives, miss critical threats, or create operational inefficiencies for security teams. This framework addresses these challenges by establishing a comprehensive, step-by-step methodology for developing, implementing, and maintaining high-quality detection rules. The overall framework can be visualised in Figure 1.

2 Rule framework

Below are the essential steps that need to be followed to develop or introduce the rule within my rule framework. Each step plays an important role to enforce soundness in the implementation process.

- Principle of the rule
- Rule priority
- Scope of each rule
- MITRE mapping if present
- Volumetry by rule
- Approval
- Testing & Validation
- Whitelist and blacklist



Figure 1: Rule implementation framework that shows all the step-by-step methodology for developing, implementing detection rules

2.1 Principle of the rule

A simple and technical explanation to identify the principle of the rule for both technical specialists and managers. For example in *DNS-exfiltration* context:

Simple explanation: DNS-exfiltration is a method that is used to steal data through Domain Name System (DNS) protocol. The threat actors attempt to embed sensitive information into DNS queries and sends them to a server that they control.

Technical explanation By analysing information in DNS-request like *TXT* records it is possible to detect data transmission to observe string or sequences in domain name. This will help to identify malicious DNS-requests.

Problem statement:

- Is it possible to see TXT records for DNS requests?
- Is it possible to establish per-host DNS behavioral baselines and detect deviations from normal query patterns?

A problem statement is needed in order to specify what type of issue we are solving by introducing new rules.

2.2 Rule priority

The priority levels that determine response procedures and processing methods. Priority assignment should consider:

- Threat severity and potential business impact
- Detection confidence level
- Required response timeframe
- Integration with existing incident response playbooks

2.3 Scope of each rule

Define the operational boundaries and applicability of the rule implementation. Specify the systems, log sources, and scenarios where the rule will be active.

2.4 MITRE mapping

What type of mapping does the rule in question fit? We should always strive to follow established framework and to map rules into categories like initial access, privilege escalation, exploitation to create coverage maps.

2.5 Volumetry by rule

The expected alert frequency for a given rule is important to understand in order to optimize rule conditions and minimize false positives. This proactive assessment helps refine detection logic and ensures sustainable operations by preventing alert fatigue and resource overload.

2.6 Approval

Define clear approval authority and criteria for rule implementation to ensure quality and organizational alignment.

2.7 Testing & Validation

The rule effectiveness and operational are assessed through systematic testing to determine the implementation feasibility, verify detection accuracy, and identify necessary optimization. We classify this detection accuracy into labels of low, medium and high to indicate the degree to correctly capture threat actor behavior based on certain criteria.

High: Rules with high confidence in detection accuracy since these are highly likely to be true positives

- A rule that accurately detects a behavior based on a CVE where the pattern is specified in detail to be translated into rule logic
- A rule that is thoroughly tested and validated in a sandbox environment under realistic attack scenarios
- A rule that is built based on a list of IOCs like domains, ips or hashes

Medium: Rules with medium confidence in detection accuracy that require analyst review to determine outcome of the alerts

- A rule that identifies behavioral patterns consistent with documented threat actor behavior but requires contextual analysis
- A rule that detects anomalous system behavior that deviates from established baselines
- A rule that detects a specific exploitation technique but lacks broader attack context

Low: Rules with low confidence in detection accuracy that require correlation and investigation from the analyst

- A rule that detects delivery or reconnaissance activities
- A rule that detects broad suspicious patterns without specific threat attribution
- A rule that needs additional correlation with other log sources

2.8 Whitelist and blacklist

Define specific criteria for approved exceptions (whitelist) to exclude known false positives and maintain lists of confirmed malicious indicators (blacklist) to enhance rule accuracy and handling procedure.

2.9 Conclusion

This framework establishes a systematic methodology for developing, implementing, and maintaining high-quality detection rules. By following these structured processes, it is possible to identify coverage gaps, and continuously refine threat detection mechanisms.